

- Contracts contain the following relative to MSSP engagements:

- o Appropriate MIS reporting commensurate with risk;
- o Agreed upon privileged access rights;
- o Termination rights and appropriate renewal language;
- o Timelines for service implementation and explicit responsibilities of the MSSP and the FI;
- o The right to modify existing services performed under the contract;
- o A security provision in accordance with the FI's security program; and
- o Ownership of data generated by proprietary security or third-party monitoring tools owned by the MSSP;

- Determine if the FI has a process to monitor that the MSSP is fulfilling their obligations outlined within the contract (e.g. Service Level Agreements (SLAs), Knowledge Performance Indicators (KPIs)/Knowledge Risk Indicators (KRIs)).

5. Evaluate the overall governance of the MSSP program.

- Appraise senior management support of the use of MSSPs;
- Review reports related to MSSP compliance with FI information security program;
- Assess changes to the information security program arising from the use of MSSPs; and
- Evaluate MIS reports provided to FI from MSSPs.

6. Evaluate the institution's process for monitoring the risk presented by the service provider relationship. Ascertain that monitoring addresses:

- Key service level agreements and contract provisions;
- Financial condition of the service provider;
- General control environment of the service provider through the receipt and review of appropriate audit and regulatory reports;
- Service provider's disaster recovery program and testing;
- Information security;
- Insurance coverage;
- Subcontractor relationships including any changes or control concerns;
- Foreign third party relationships; and
- Potential changes due to the external environment (i.e., competition and industry trends).

7. Review policies regarding periodic ranking of service providers by risk.

The decision process should:

- Include objective criteria;
- Support consistent application;
- Consider the degree of service provider support for the institution's strategic and critical business needs; and
- Specify subsequent actions when rankings change.

8. Evaluate the financial institution's use of user groups and other mechanisms to monitor and influence the service provider.

Objective 4: Discuss corrective action and communicate findings.

1. Determine the need to complete Tier II Procedures for additional validation to support conclusions related to any of the Tier I Objectives.

2. Review preliminary conclusions with the EIC regarding:

- Violations of law, rulings, regulations;
- Significant issues warranting inclusion in the Report as matters requiring attention or recommendations; and
- Potential impact of your conclusions on the institution's risk profile and composite or component IT ratings.

3. Discuss findings with management, and obtain proposed corrective

action for significant deficiencies.

4. Document conclusions in a memo to the EIC that provides report ready comments for the Report of Examination and guidance to future examiners.

5. Organize work papers to ensure clear support for significant findings by examination objective.

TIER II OBJECTIVES AND PROCEDURES

A. IT REQUIREMENTS DEFINITION

1. Review documentation supporting the requirements definition process to ascertain that it appropriately addresses:

- Scope and nature;
- Standards for controls;
- Minimum acceptable service provider characteristics;
- Monitoring and reporting;
- Transition requirements;

- Contract duration, termination, and assignment; and
- Contractual protections against liability.

B. DUE DILIGENCE

1. Assess the extent to which the institution reviews the financial stability of the service provider:

- Analyzes the service provider's audited financial statements and annual reports;
- Assesses the provider's length of operation and market share;
- Considers the size of the institution's contract in relation to the size of the company;
- Reviews the service provider's level of technological expenditures to ensure on-going support; and
- Assesses the impact of economic, political, or environmental risk on the service provider's financial stability.

2. Evaluate whether the institution's due diligence considers the following:

- References from current users or user groups about a particular vendor's reputation and performance;

- The service provider's:

- o Experience and ability in the industry;
- o Experience and ability in handling situations similar to the Institution's environment and operations;
- o Shortcomings in the service provider's expertise that the institution may need to supplement in order to fully mitigate risks;
- o Proposed use of third parties, subcontractors, or partners to support the outsourced activities;
- o A ability to respond to service disruptions;
- o Assigning of Key personnel that would support the institution;
- o Ability to comply with appropriate federal and state laws.

In particular, ensure management has assessed the providers' ability to comply with federal laws (including GLBA and the USA PATRIOT Act);

- The cost for additional system and data conversions or interfaces presented by the various vendors; and

- Country, state, or locale risk.

3. Evaluate how the FI determines whether the MSSP meets its risk profile.

Consider whether the FI:

- Performed an onsite visitation of the MSSP; Considered business changes at the MSSP;

- Assessed the extent of MSSP use of subcontractors and if any will be performed by an offshore entity; and
- Evaluated controls over sensitive data where offshore subcontracting is performed.

C. SERVICE CONTRACT

1. Verify that legal counsel reviewed the contract prior to signing. Ensure that:

- Legal counsel is qualified to review the contract particularly if it is based on the laws of a foreign country or other state; and
- Legal review includes an assessment of the enforceability of local contract provisions and laws in foreign or out-of-state jurisdictions.

2. Verify that the contract appropriately addresses:

- Scope of services;
- Performance standards;
- Pricing;
- Controls;
- Financial and control reporting;

- FIs right to audit;
- Ownership of data and programs;
- Confidentiality and security;
- Regulatory compliance;
- Indemnification;
- Limitation of liability;
- Dispute resolution;
- Contract duration;
- Restrictions on, or prior approval for, subcontractors;
- Termination and assignment, including timely return of data in a machine-readable format;

- Insurance coverage;
- Prevailing jurisdiction (where applicable);
- Choice of law (foreign outsourcing arrangements);
- Regulatory access to data and information necessary for supervision; and
- Business Continuity Planning.

3. Review service level agreements to ensure they are adequate and measurable. Consider whether:

- Significant elements of the service are identified and based on the institution's requirements;
- Objective measurements for each significant element are defined;
- Reporting of measurements is required;
- Measurements specify what constitutes inadequate performance; and

- Inadequate performance is met with appropriate sanctions, such as reduction in contract fees or contract termination.

4. Review the institution's process for verifying billing accuracy and monitoring any contract savings through bundling.

D. MONITORING SERVICE PROVIDER RELATIONSHIP(S)

1. Evaluate the institution's periodic monitoring of the service provider relationship(s), including:

- Timeliness of review, given the risk from the relationship;
- Changes in the risk due to the function outsourced;
- Changing circumstances at the service provider, including financial and control environment changes;
- Conformance with the contract, including the service level agreement; and
- Audit reports and other required reporting addressing business continuity, security, and other facets of the outsourcing relationship.

2. Determine if adequate in house expertise exists to manage an MSSP relationship by evaluating:

- FI management's understanding of the MSSP's process, procedures, and protocols;